



Università degli studi di Salerno

Secure-by-Design IoT Architecture for Healthcare Monitoring

Hardening the C.A.R.E. Framework through mTLS and Blockchain Data Notarization

Exams

Iot Security &
Sicurezza Dei Dati

Student

Crescenzo Esposito
0522502068



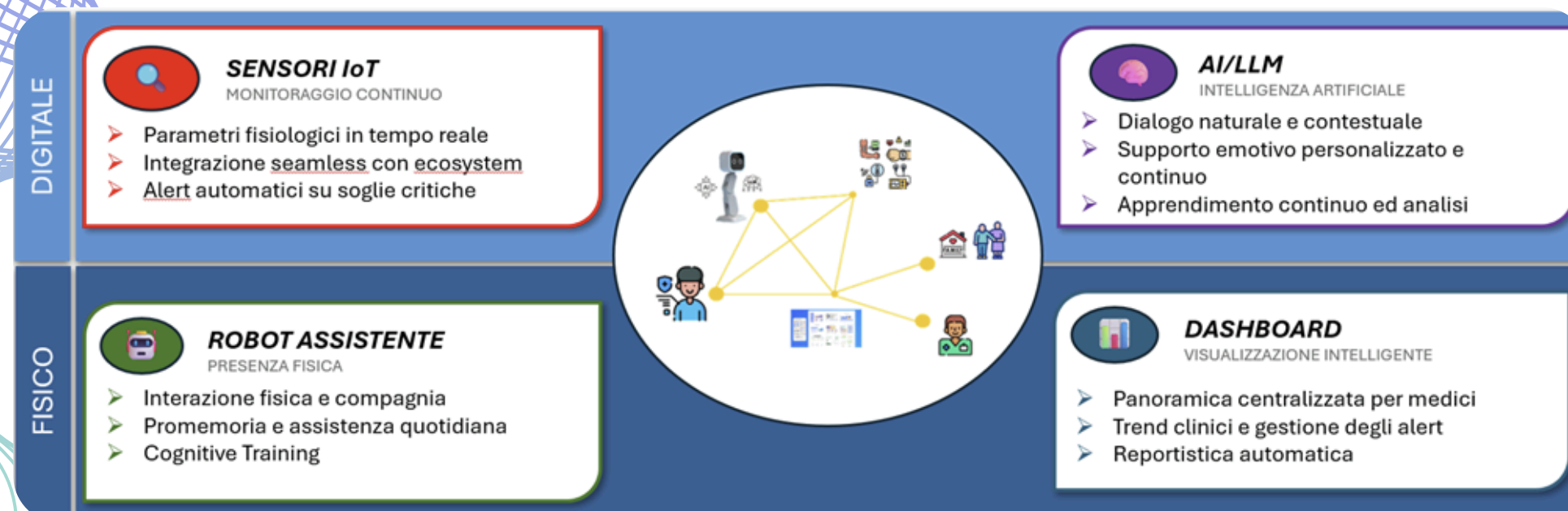
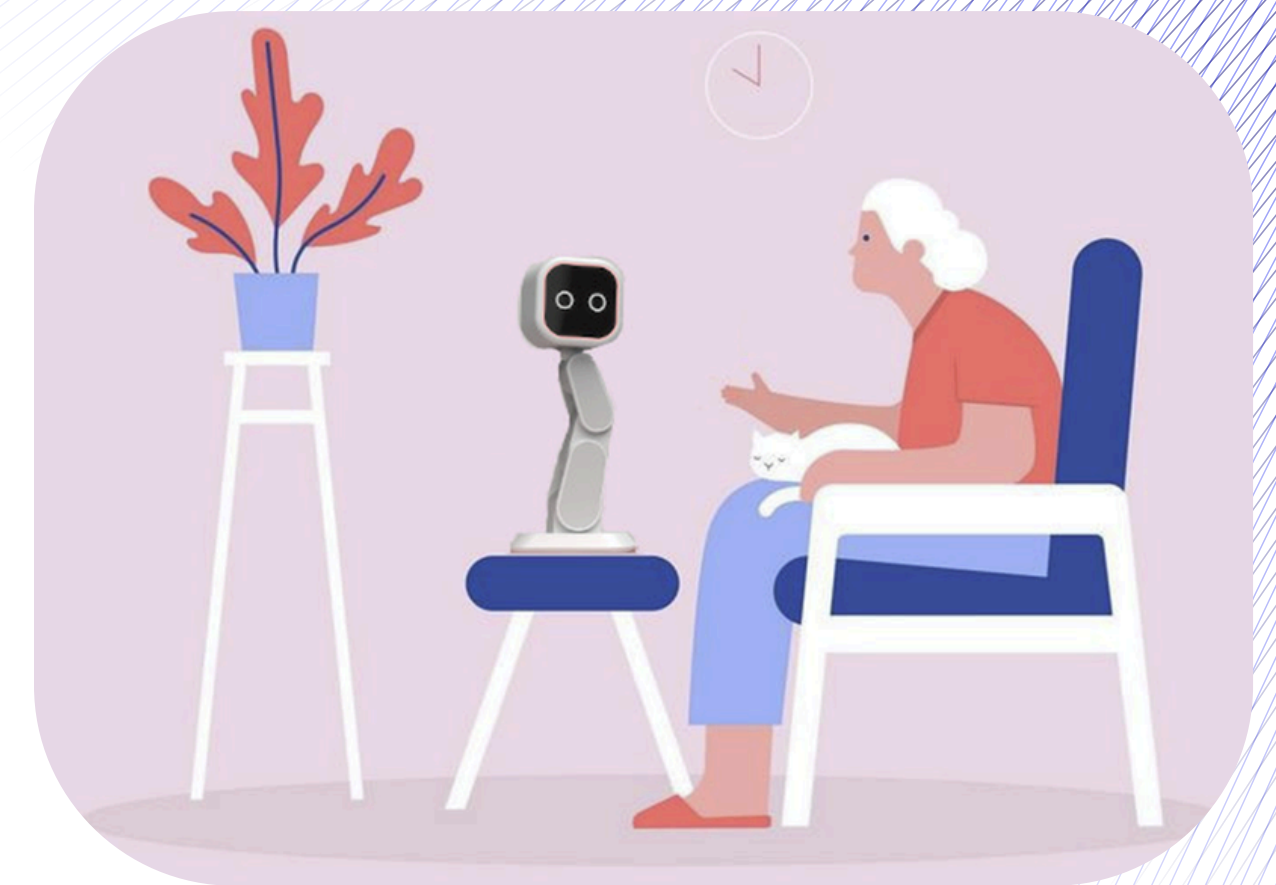
Scan for Source Code & PoC

The C.A.R.E. Framework

Multimodal Monitoring for Active Assisted Living (AAL)

In response to the challenge of demographic aging, a **robotic assistant** capable of monitoring elderly people suffering from comorbidity has been developed.

The goal is to move beyond passive monitoring by offering proactive and empathetic support through Artificial Intelligence.



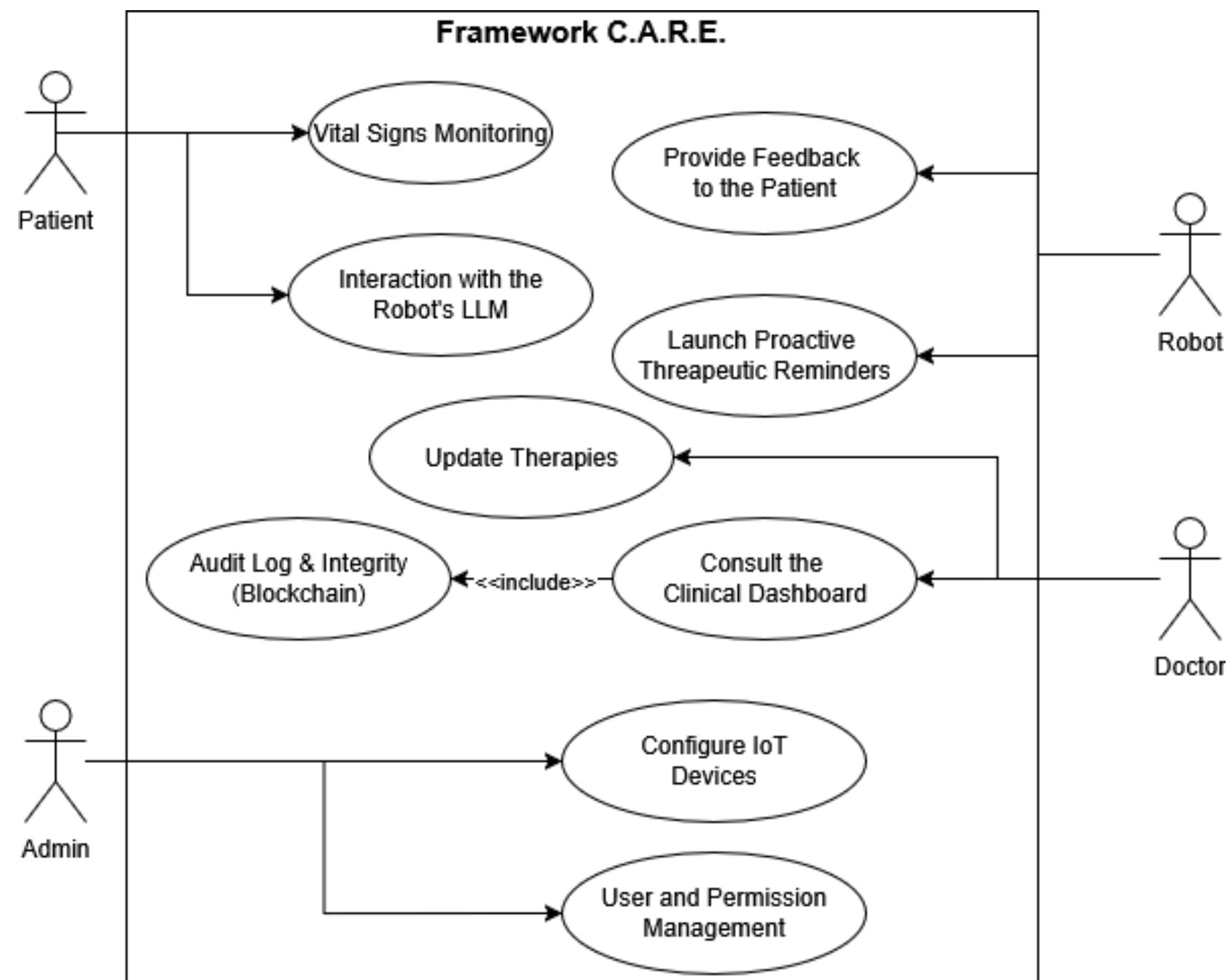
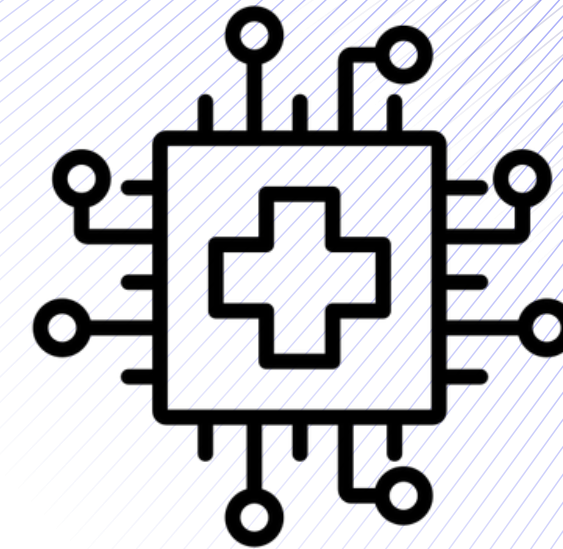
The system integrates a heterogeneous set of consumer biomedical devices communicating via BLE. The collected data feeds the robot's decision-making engine.

The C.A.R.E. Framework

Requirements Analysis

The system involves **human actors** (patient, doctor) and **artificial agents** (robot, gateway).

High-level features (e.g., Nutritional Support, Medical Alerts) depend heavily on the **reliability** of sensor data.



If the data is **compromised**, the robot may give incorrect suggestions or trigger unnecessary alerts.

The goal was to ensure that the data consumed is **authentic** and **intact**.

Security Requirements



Confidentiality

- The data stream contains sensitive parameters (e.g., blood glucose, SpO2) which, according to Art. 32 of the GDPR, must be rendered unintelligible to unauthorized third parties.



Integrity

- Ensure that data is not altered during transit. Even the slightest change in a value can trigger false alarms from the robot.



Authenticity

- Verify the identity of the source with certainty. The gateway must only accept connections from legitimate medical devices.



Non-repudiation

- Every critical measurement must be traceable, preventing the generation of data from being denied retrospectively.

Security Requirements

Current System

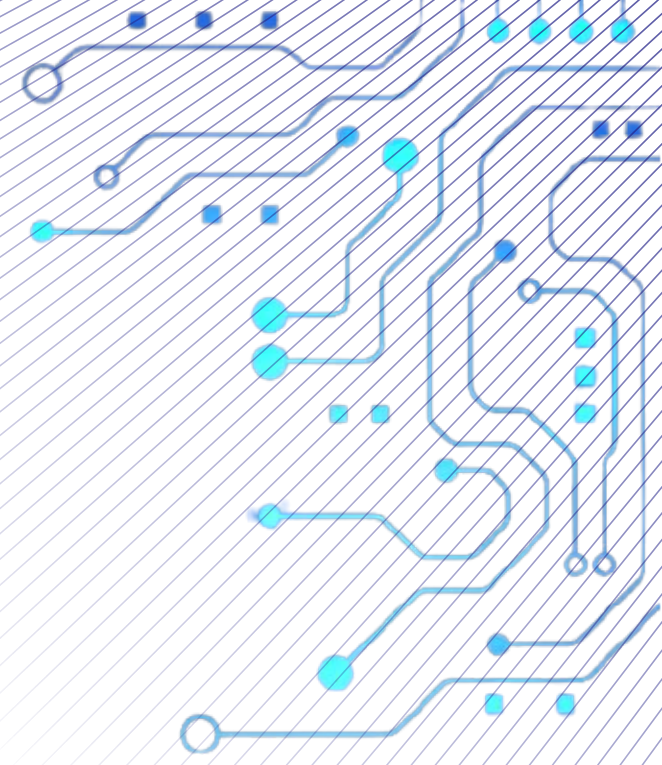
Analysis of the original Gateway source code revealed critical architectural vulnerabilities.

The authentication mechanism is based exclusively on a **Whitelist** of MAC addresses. Furthermore, data is **transmitted in clear text** in both BLE and MQTT communications.

- **Confidentiality:** Sensitive data exposed to sniffing
- **Integrity:** Risk of data alteration
- **Authenticity:** Impossibility of verifying the actual source of the data

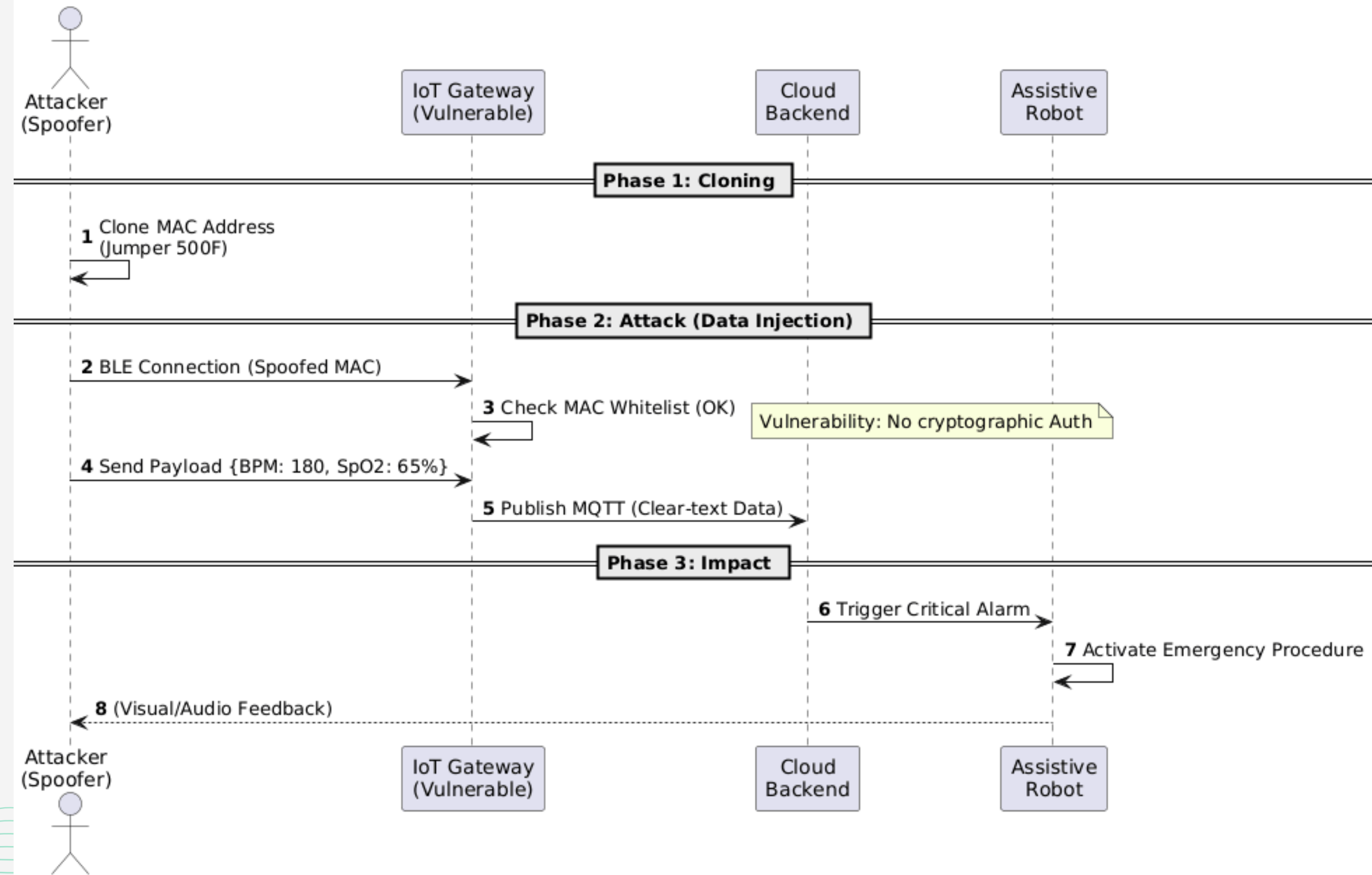


To demonstrate the clinical impact of this flaw, a simulated attack was developed using an **ESP32** microcontroller programmed to clone the MAC address of a Jumper 500F pulse oximeter on the whitelist.



MAC Spoofing and Data Injection

- The **attacker** overwrites the hardware address of their device with that of the victim.
- The **Gateway** detects the MAC in the whitelist and automatically establishes the connection without requiring cryptographic keys or secure pairing.
- Once connected, the attacker injects a malicious payload containing falsified critical parameters via notification.



Serial Monitor ESP32

```
entry 0x400805e4
Avvio Evil ESP32 Jumper...
MAC Base impostato con successo!
MAC Address BLE Attivo: 12:a2:00:2d:65:03
In attesa del Gateway...
>> GATEWAY CONNESSO! Inizio iniezione dati...
-> Pacchetto INIETTATO: BPM=180 SpO2=65 [Hex: 81 B4 41 0F]
-> Pacchetto INIETTATO: BPM=180 SpO2=65 [Hex: 81 B4 41 0F]
```

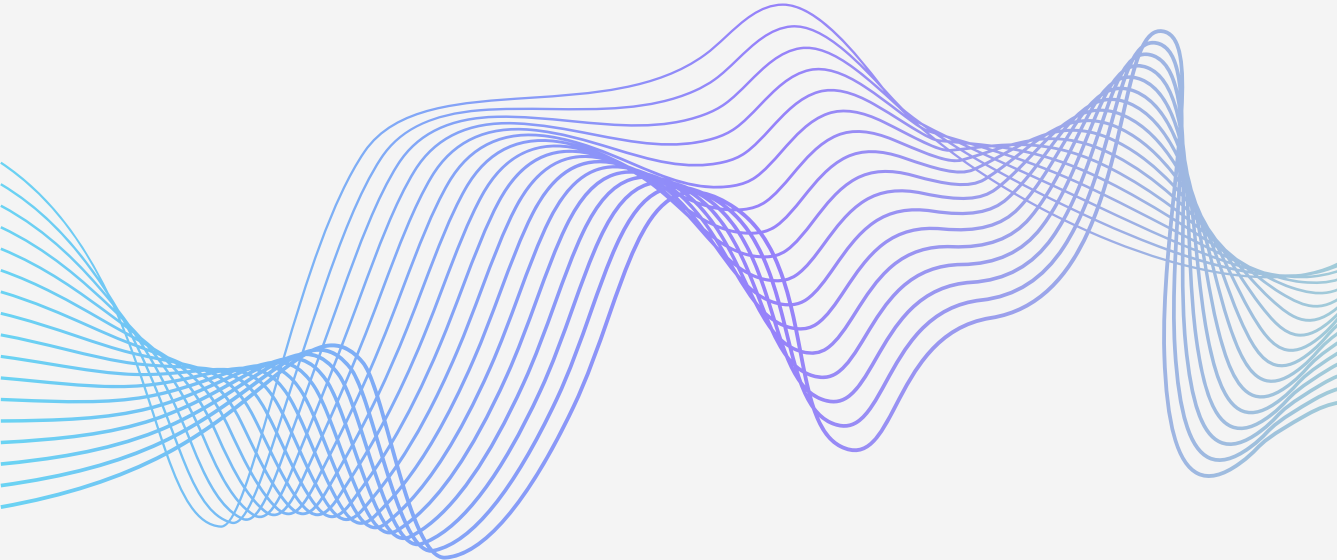
Log Gateway C.A.R.E.

```
INFO - configuration - Attempting to load configuration from conf\config.json
INFO - configuration - Successfully parsed configuration for user 0cd2a3fc-0613-4d76-b154-1d3e195efc4a
INFO - Gateway main - {'12:A2:00:2D:65:03': <DeviceType.PULSEOXIMETER: 'pulseoximeter'>, 'C2:32:74:BD:11:EA': <DeviceType.SCALE: 'scale'>, 'C0:26:DA:2F:6D:D8': <DeviceType.GLUCOMETER: 'glucometer'>}
INFO - Pulseoximeter device - Connected to 12:A2:00:2D:65:03: True
INFO - Pulseoximeter device - Nothing to do on post connect for this device
INFO - Pulseoximeter device - Listening for notifications on 12:A2:00:2D:65:03
INFO - Pulseoximeter device - Data from cdeacb81-5235-4c07-8846-93a37ee6b86d: 81b4410f
INFO - Pulseoximeter device - Data from Pulseoximeter device:12:A2:00:2D:65:03 -> BPM : 180, SpO2 : 65, PI : 1.5
INFO - Pulseoximeter device - Data from cdeacb81-5235-4c07-8846-93a37ee6b86d: 81b4410f
INFO - Pulseoximeter device - Data from Pulseoximeter device:12:A2:00:2D:65:03 -> BPM : 180, SpO2 : 65, PI : 1.5
```

```
{ } config.json > [ ] devices > { } 0 > abc mac
{
  "user_id": "0cd2a3fc-0613-4d76-b154-1d3e195efc4a",
  "devices": [
    {
      "type": "pulseoximeter",
      "mac": "12:A2:00:2D:65:03",
      "id": "ffe63f86-f5d9-47be-96d8-31a9664baccc"
    },
    {
      "type": "wbp",
      "mac": "C2:32:74:BD:11:EA",
      "id": "ffe63f86-f5d9-47be-96d8-31a9664baccc"
    },
    {
      "type": "scale",
      "mac": "CA:20:21:01:1B:5D",
      "id": "ffe63f86-f5d9-47be-96d8-31a9664baccc"
    }
  ]
}
```

MAC Spoofing and Data Injection

- The only security barrier is a **static check** on the MAC address.
- The log confirms the **spoofing** and immediate connection.
- Cyclical **injection of packets** to simulate cardiac arrest (BPM 180).
- The gateway accepts the packet 0x81... believing it to be authentic.
- The system propagates the alarm, demonstrating that the integrity of the monitoring system has been **compromised**.



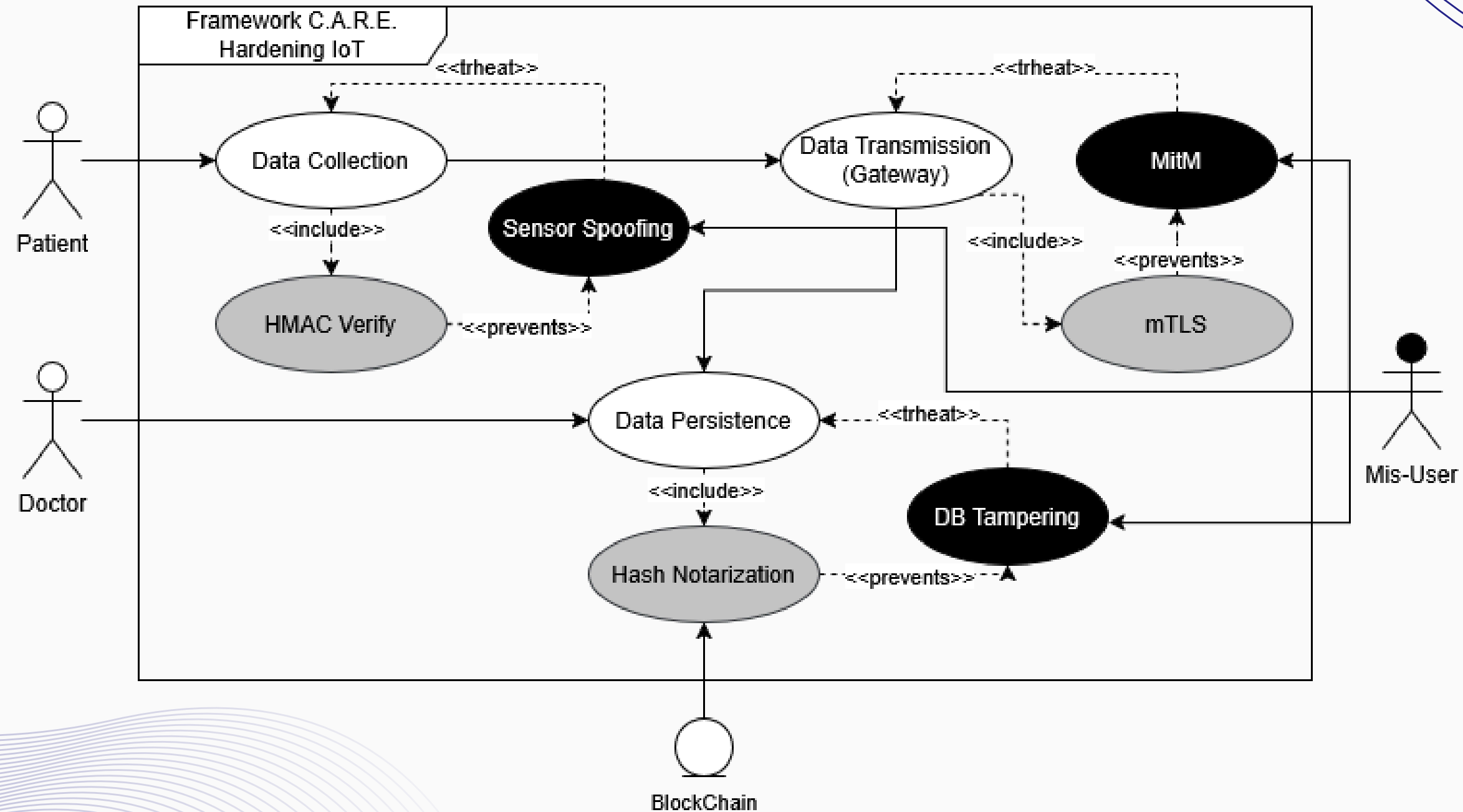
Threat Modeling & Security Requirements

Misuse Case Diagram

Misuse Case diagrams were used to map vulnerabilities to architectural countermeasures.

Identified Attack Vectors:

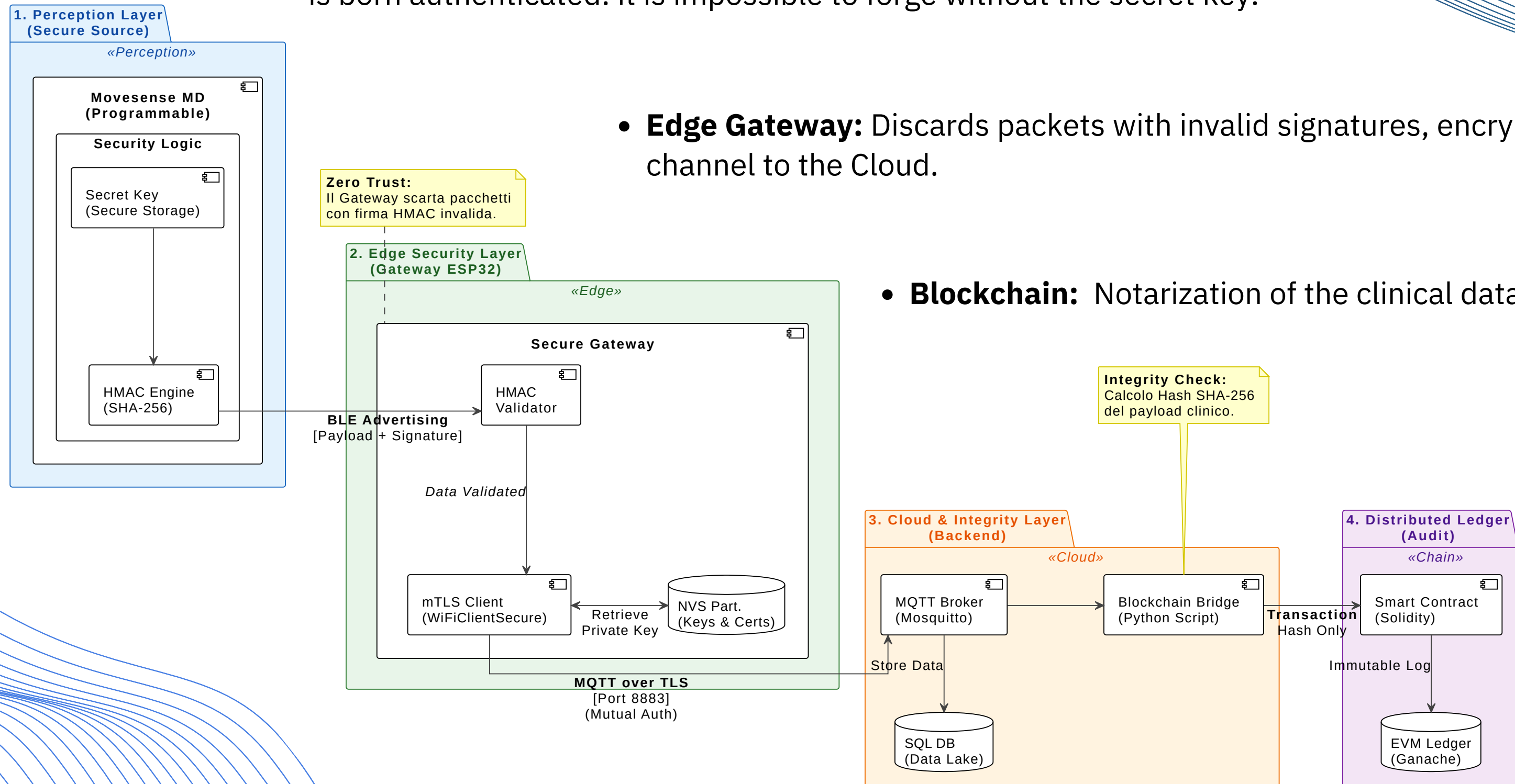
1. **Sensor Spoofing:** Injection of false data
2. **Rogue Gateway:** Malicious gateways in the home network
3. **Data Tampering:** Tampering with clinical records



Trustless Architecture

From sensor to blockchain

- **Secure Source:** On-board HMAC-SHA256 signature generation. Data is born authenticated: it is impossible to forge without the secret key.



- **Edge Gateway:** Discards packets with invalid signatures, encrypted channel to the Cloud.

- **Blockchain:** Notarization of the clinical data hash on EVM Ledger

Secure IoT Gateway Design

Modello "Zero Trust" e Security-by-Design

To mitigate the identified vulnerabilities, an ESP32-based Gateway was developed to move away from hardware-level trust in favor of standard cryptographic protocols. A three-layer security stack was then integrated to **protect data at the source, during transport, and in identity.**



Secure Transport & Strong Identity

The encrypted tunnel protects against sniffing, while the exchange of X.509 certificates ensures that only authorized gateways can communicate with the cloud, eliminating the risk of rogue gateways.



Integrity at Source

Lightweight digital signature. Using a pre-shared secret key, each BLE payload is "sealed." Any attempt at data injection or in-transit modification invalidates the signature, causing the packet to be immediately rejected.



Immutability & Non-Repudiation

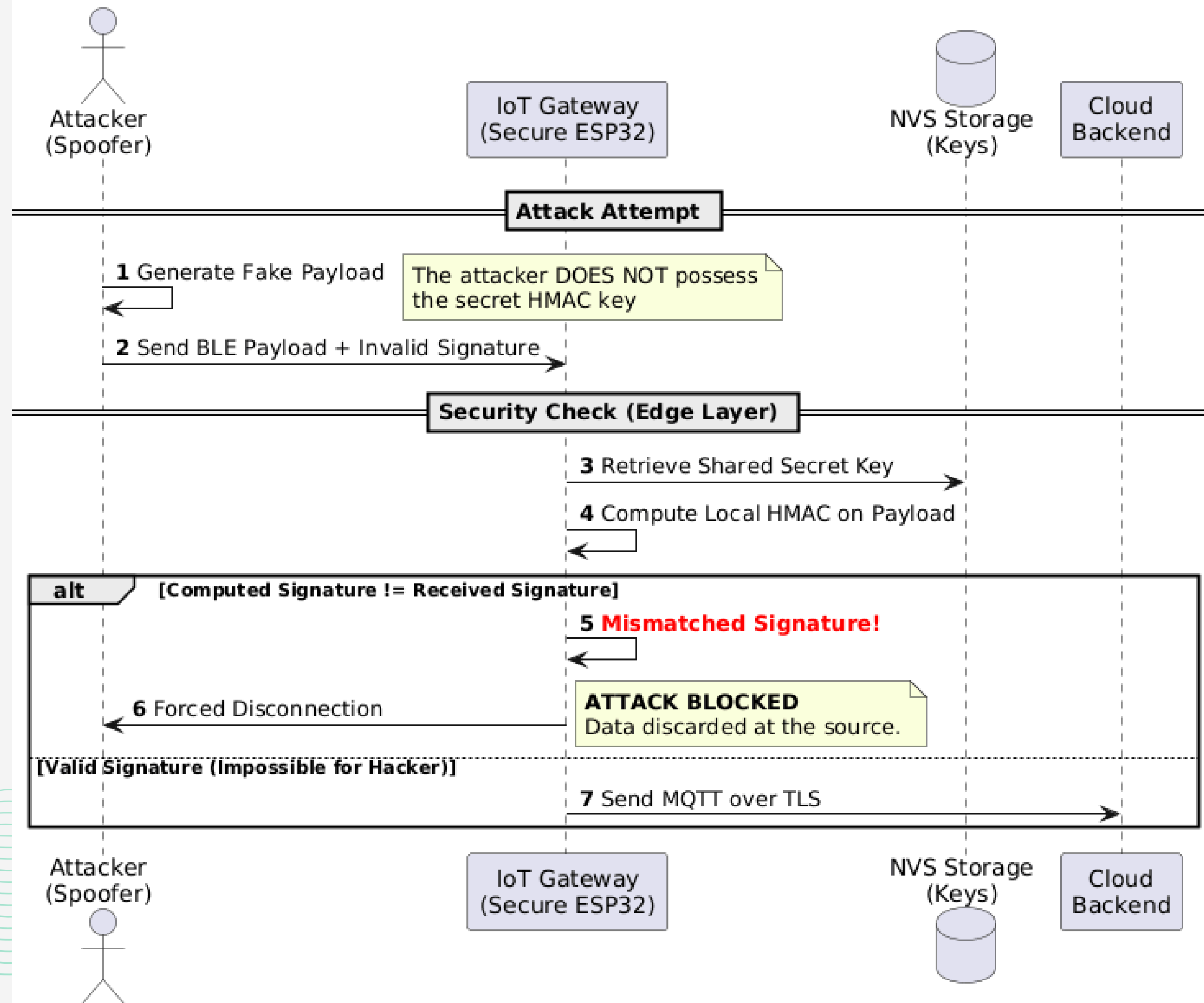
Notarization of the digital fingerprint of clinical data. The Smart Contract acts as a digital notary, making the data unalterable. If the SQL Database is tampered with, comparison with the Hash on the Blockchain will reveal the inconsistency.

Effectiveness of Countermeasures

Defense Mechanism: The Gateway acts as a Security Enforcement Point.

Results:

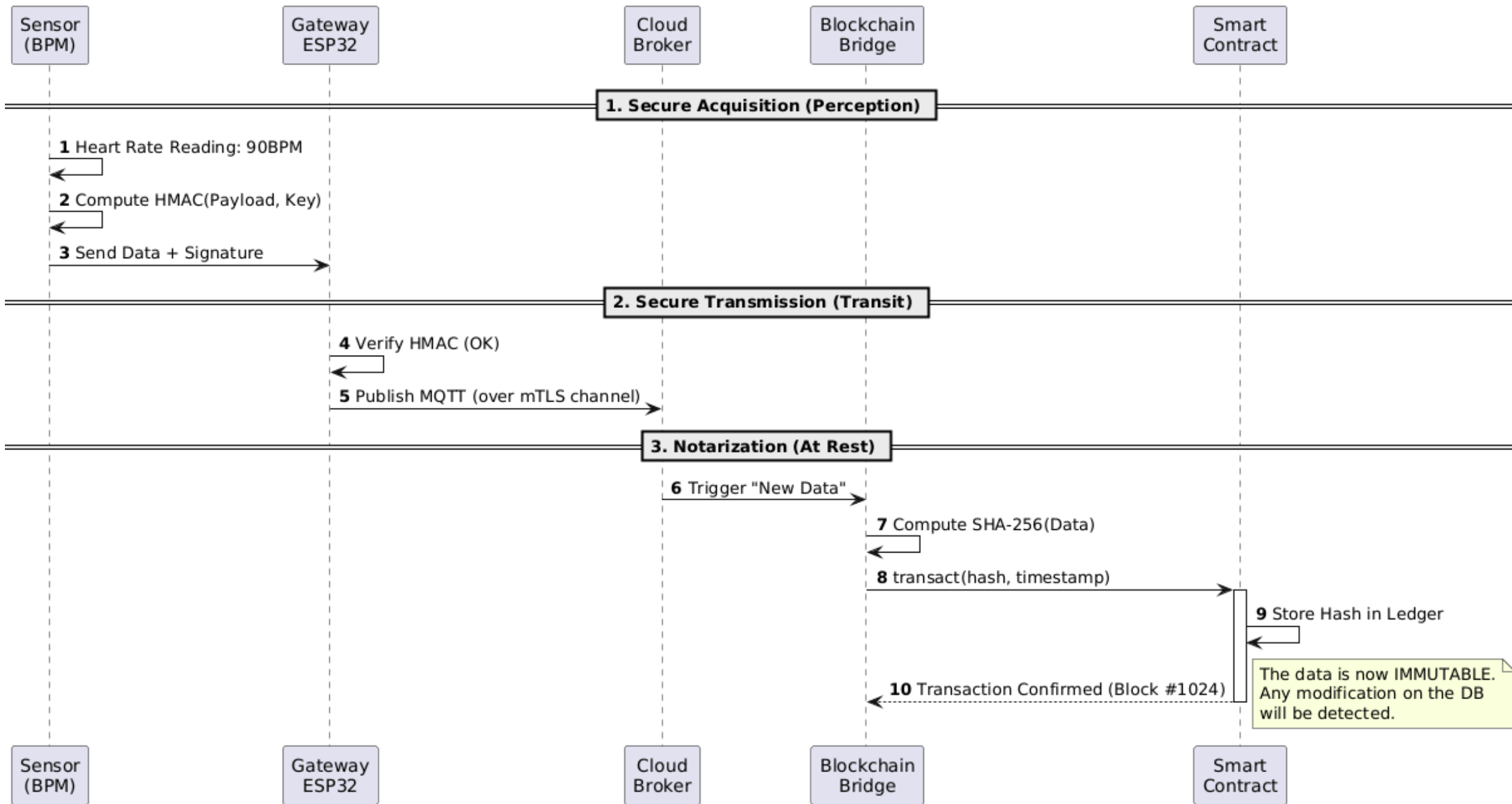
- Unsigned (or incorrectly signed) payload gets detected.
- The packet is discarded at the Edge before it reaches the Cloud.
- The attacker cannot replicate the signature without the secret key.



Data Integrity & Non-Repudiation

Blockchain role: provide immutable "Audit Trail"

- **Privacy:** No unencrypted clinical data ends up on the chain. Only the SHA-256 hash is notarized.
- **Smart Contract:** It acts as a “Digital Notary,” certifying the existence and integrity of data at a specific point in time.



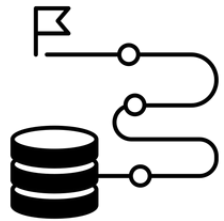
Conclusions

Summary of Results



Hardening of C.A.R.E. Framework

- The architecture based on implicit trust has been superseded by the implementation of a **Zero Trust** model



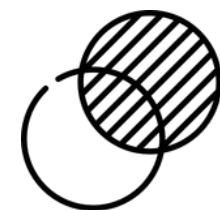
From Data to Clinical Decision

- By guaranteeing the integrity of the data at source, we have ensured patient safety: the robot can provide nutritional and therapeutic advice based on certified, unaltered values



Non-Repudiation and Compliance

- The use of **Blockchain** provides an immutable audit trail, which is essential for medical-legal accountability and regulatory compliance.



Operational Transparency

- All security measures are transparent to the elderly user: interaction remains natural, without requiring complex actions on the part of the user

Future Works

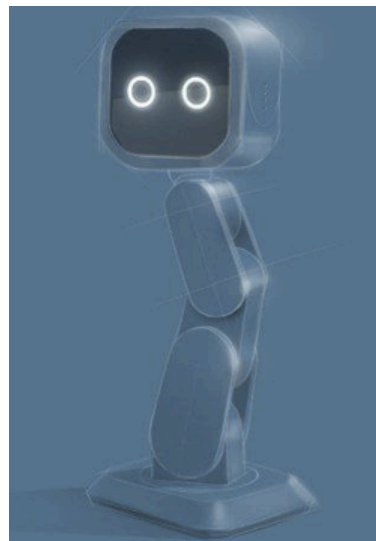
Hardware Deployment & Indoor Localization

From **PoC** to distributed **Medical Grade EcoSystem**:

- **Continuous Sensing:** Development on Movesense MD, a programmable medical-grade sensor
- **Robot Gateway:** High-throughput mTls communication management and offloading of local AI algorithms
- **Ambient Intelligence:** Deployment of Nordic **nRF5340-DK** nodes as environmental hubs and triangulation vis RSSI or AoA to track the patient



Movesense MD



Probot

From **public Testnet** to a **Permissioned Blockchain**:

- **Adoption of Hyperledger Fabric**
 - Transition to a private DLT to eliminate Gas Fees and ensure scalability
- **Granular Privacy**
 - Use of channels to segregate sensitive data, ensuring access only to authorized clinical staff
- **Identity Management:**
 - Integration between Fabric's CA and device mTLS certificates